

FUTURE INTERNS FELLOWSHIP PROGRAM
CYBERSECURITY INTERNSHIP TASK

VULNERABILITY ASSESSMENT REPORT

Target: www.news24.com

Prepared By	Makgomo Koketso Raphela
Date	10 June 2026
Assessment Type	Passive Reconnaissance
Tools Used	Nmap · DevTools · SecurityHeaders.com · OWASP ZAP
Overall Risk	MEDIUM

Ethical Notice & Disclaimer

This assessment was conducted strictly within ethical boundaries. Only passive, non-intrusive techniques were used — including port scanning, HTTP header inspection, browser console analysis, and traffic observation via OWASP ZAP in passive mode. This report follows the scope defined by the Future Interns Fellowship Program.

NOT ALLOWED	IN SCOPE
Login bypass or authentication testing	Public-facing pages only
Exploitation of any vulnerability	Passive scanning and observation
Brute force attacks	HTTP header checks
Denial-of-Service (DoS) attacks	Configuration analysis
Any activity that could harm the website	Browser DevTools inspection

Executive Summary

A passive vulnerability assessment was conducted on News24 (www.news24.com), South Africa's most visited online news platform. The objective was to identify exposed services, check security configurations, and evaluate the overall security posture using read-only, non-intrusive methods including Nmap port scanning, HTTP response header analysis, browser DevTools inspection, and OWASP ZAP passive scanning.

News24 scored an A grade on SecurityHeaders.com, indicating strong header configuration, and is protected by Cloudflare CDN. However, non-standard ports 8080 and 8443 are publicly accessible, an outdated JavaScript library is actively loaded in production, console errors expose internal details, and several first-party cookies lack the Secure flag.



Scope & Assessment Details

TARGET URL	https://www.news24.com
RESOLVED IP	104.17.251.6 (Cloudflare Edge Node)
ADDITIONAL IPs	104.17.250.6 2606:4700::6811:fa06 2606:4700::6811:fb06
ENVIRONMENT	Public Internet — Cloudflare-proxied production site
TESTING MACHINE	Windows 11 — Nmap 7.99
SCAN COMMAND	nmap -sV --top-ports 100 www.news24.com -oN news24_scan.txt
SCAN DURATION	25.88 seconds
SCAN DATE	Tue 10 June 2026 19:29 – 19:29 SAST
ASSESSMENT TYPE	Passive — Port Scan, Header Analysis, Console Review, ZAP Passive

Methodology

The following methodology was applied during the assessment:

	Reconnaissance	Basic information gathering on the target domain and hosting infrastructure.
02	Port Scanning	Top 100 TCP ports scanned using Nmap with service version detection (-sV flag).
	Header Analysis	HTTP security response headers inspected via Browser DevTools and SecurityHeaders.com.
04	Cookie Inspection	Browser Application tab used to review cookie flags: Secure, HttpOnly, SameSite.
	Console Review	Browser console examined for JavaScript errors, deprecated APIs, and information leakage.
06	Passive ZAP Scan	OWASP ZAP run in passive mode — observing traffic without sending attack payloads.
	Risk Classification	Each finding rated Low / Medium / High based on likelihood and potential impact.

Nmap Scan Results

Command executed:

```
nmap -sV --top-ports 100 www.news24.com -oN news24_scan.txt
```

PORT	STATE	SERVICE	VERSION / NOTES	RISK
80/tcp	Open	HTTP	Cloudflare HTTP proxy	MEDIUM
443/tcp	Open	HTTPS	Cloudflare SSL/HTTP proxy	LOW
8080/tcp	Open	HTTP Alt	Non-standard port — publicly open	HIGH
8443/tcp	Open	HTTPS Alt	Non-standard port — publicly open	MEDIUM
96 ports	Filtered	—	Blocked by firewall / no response	INFO

Note: Because News24 uses Cloudflare as a reverse proxy, Nmap only observes Cloudflare's edge servers — not the actual origin server. This prevents enumeration of the backend OS and software stack, which is a positive security control.

Security Headers Analysis

Source: securityheaders.com — Scanned 10 June 2026 | Grade: A

(Grade capped at A from A+ due to warnings — see below)

HEADER	VALUE	STATUS
Content-Security-Policy	frame-ancestors 'none' only	WEAK
Strict-Transport-Security	max-age=31536000; includeSubDomains; preload	PASS
X-Frame-Options	DENY	PASS
X-Content-Type-Options	nosniff	PASS
Referrer-Policy	strict-origin-when-cross-origin	PASS
Permissions-Policy	Present	PASS
Feature-Policy	Present — deprecated header (should be removed)	WARN

The Content-Security-Policy header is present but only specifies frame-ancestors 'none'. A comprehensive CSP covering script-src, img-src, and connect-src directives is absent, leaving XSS attack vectors only partially mitigated.

The screenshot shows the securityheaders.com interface. At the top, there's a search bar with 'www.news24.com' and a 'Scan' button. Below this, the 'Security Report Summary' section shows a large green 'A' grade. The report details the site as 'http://www.news24.com/' and lists the following headers with green checkmarks: Content-Security-Policy, Permissions-Policy, Referrer-Policy, X-Content-Type-Options, and X-Frame-Options. A warning message states 'Grade capped at A, please see warnings below.' and an 'Advanced' section suggests performing a deeper security analysis. The 'Warnings' section is partially visible at the bottom.

Vulnerability Findings

FINDING 1 of 9

Non-Standard Ports 8080 & 8443 Publicly Exposed

HIGH

DESCRIPTION

Ports 8080 and 8443 are publicly reachable and running HTTP/HTTPS services via Cloudflare. These are non-standard ports typically used for development, staging, or proxy management — not for a production public-facing news site. Their exposure unnecessarily increases the attack surface.

EVIDENCE

8080/tcp open http Cloudflare http proxy 8443/tcp open ssl/http Cloudflare http proxy

BUSINESS IMPACT	REMEDIATION
→ Potential access to staging or admin interfaces → Wider attack surface for probing and reconnaissance → May bypass WAF rules configured on port 443 only	✓ Restrict ports 8080 and 8443 via firewall if not required publicly ✓ Review Cloudflare port configuration and disable unused ports ✓ Redirect all traffic to port 443 only

FINDING 2 of 9

HTTP Port 80 Accepts Unencrypted Traffic

HIGH

DESCRIPTION

Port 80 (HTTP) is open and accepting unencrypted connections. While Cloudflare may redirect users to HTTPS, the open port creates a window for man-in-the-middle attacks where traffic is intercepted before the redirect occurs, particularly on unsecured networks.

EVIDENCE

80/tcp open http Cloudflare http proxy

BUSINESS IMPACT	REMEDIATION
→ User credentials or session tokens could be intercepted → Content injection possible before HTTPS redirect occurs → Violates HSTS best practices for media platforms handling user accounts	✓ Enable HSTS via Cloudflare dashboard ✓ Configure automatic HTTP to HTTPS redirect at CDN level ✓ Set HSTS max-age to at least 31,536,000 seconds (1 year)

FINDING 3 of 9 Outdated JavaScript Library in Production — insight.old.min.js**MEDIUM****DESCRIPTION**

The browser console reveals that a script named insight.old.min.js is actively loaded and throwing uncaught TypeErrors. The ".old" suffix strongly indicates a legacy library that has not been removed from production. Outdated JavaScript libraries frequently contain known CVEs.

EVIDENCE

```
TypeError: Cannot assign to read only property 'pushState' of object '#' at
insight.old.min.js:1:50641 ErrorData: {"domain":"news24.com"}
```

BUSINESS IMPACT

- Legacy JS libraries may contain known, exploitable CVEs
- Runtime errors indicate unstable code running in production
- Internal domain names and file paths exposed via stack traces

REMEDIATION

- ✓ Audit all loaded JS files and remove .old legacy versions
- ✓ Replace with current, maintained library version
- ✓ Implement JS dependency scanning in CI/CD pipeline

FINDING 4 of 9 Browser Console Errors Publicly Visible (13 Issues)**MEDIUM****DESCRIPTION**

News24's browser console exposes 13 issues including uncaught TypeErrors, deprecated Google Ad API warnings, and Mantis script configuration errors. Any user who opens DevTools can see these, providing attackers with detailed information about the site's technology stack.

EVIDENCE

```
[GPT] PubAdsService.setTargeting is deprecated [GPT] Using deprecated
googletag.encryptedSignalProviders Mantis-Script: Function fetchData returned error - "signal timed
out"
```

BUSINESS IMPACT

- Technology stack and third-party integrations revealed to attackers
- Deprecated APIs indicate maintenance gaps in the codebase
- Script timeouts suggest instability under load

REMEDIATION

- ✓ Suppress console output in production builds
- ✓ Update Google Publisher Tag to current version
- ✓ Fix or remove Mantis script configuration errors

FINDING 5 of 9 First-Party Cookies Missing Secure Flag**MEDIUM****DESCRIPTION**

Several News24 first-party cookies (`_eoi`, `_gads`, `_gpi`, `__iat_vis`) do not have the Secure flag set. This means these cookies can be transmitted over unencrypted HTTP connections, exposing them to interception. Combined with port 80 being open, this is a compounded risk.

EVIDENCE

```
_eoi - Secure: NO | SameSite: None _gads - Secure: NO | SameSite: None _gpi - Secure: NO | SameSite: None __iat_vis - Secure: NO | SameSite: Lax
```

BUSINESS IMPACT

- Cookies transmitted over HTTP can be stolen by network attackers
- SameSite=None without Secure flag is a known misconfiguration
- Advertising and tracking cookies expose user behaviour data

REMEDIATION

- ✓ Set Secure flag on all first-party cookies
- ✓ Set SameSite=Strict or Lax for cookies that do not need cross-site access
- ✓ Audit all third-party cookie configurations regularly

FINDING 6 of 9 Narrow Content-Security-Policy Scope**MEDIUM****DESCRIPTION**

The Content-Security-Policy header is present but only specifies frame-ancestors 'none'. This means clickjacking is blocked, but the policy does not restrict JavaScript sources, image sources, or connection endpoints — leaving XSS attack vectors partially unmitigated.

EVIDENCE

```
Content-Security-Policy: frame-ancestors 'none'
```

BUSINESS IMPACT

- XSS payloads can load external malicious scripts
- No restriction on which domains can be connected to
- Injected content can load images or resources from attacker-controlled servers

REMEDIATION

- ✓ Expand CSP to include script-src, img-src, and connect-src directives
- ✓ Use nonce-based or hash-based CSP for inline scripts
- ✓ Test CSP changes in report-only mode before enforcing

FINDING 7 of 9 Deprecated Feature-Policy Header in Use**LOW****DESCRIPTION**

The Feature-Policy response header is present but this header was deprecated in favour of Permissions-Policy. Serving deprecated headers can cause browser warnings and signals that the security header configuration has not been recently reviewed.

EVIDENCE

`Feature-Policy: accelerometer 'none'; autoplay 'none'; camera 'none'...`

BUSINESS IMPACT

- Browser compatibility issues as Feature-Policy support is removed
- Signals outdated security configuration to security researchers
- Permissions-Policy (the replacement) may not be correctly configured

REMEDIATION

- ✓ Remove the Feature-Policy header from server responses
- ✓ Ensure Permissions-Policy is correctly configured as the replacement
- ✓ Schedule regular security header configuration reviews

FINDING 8 of 9**Cloudflare Rate Limiting Blocked Automated Scanning — Positive Control****INFO****DESCRIPTION**

During OWASP ZAP passive scanning, all automated requests were immediately blocked with HTTP 429 (Too Many Requests). Cloudflare's bot detection identified and rate-limited the scanner within milliseconds, preventing enumeration of the site structure.

EVIDENCE

`HTTP/429 Too Many Requests Reason: Too Many Requests Response time: 27-77ms All requests blocked simultaneously at 12:56:32 SAST`

BUSINESS IMPACT

- This is a **POSITIVE** security control
- Automated attacks and scraping tools are effectively blocked
- Confirms Cloudflare WAF is actively protecting the site

REMEDIATION

- ✓ Maintain Cloudflare rate limiting rules and keep them active
- ✓ Review rate limiting thresholds regularly
- ✓ Consider adding CAPTCHA challenges for repeated offenders

FINDING 9 of 9 Cloudflare CDN Masking Origin Server — Positive Control

INFO

DESCRIPTION

Nmap was unable to enumerate the origin web server OS, software version, or backend infrastructure because Cloudflare acts as a reverse proxy. This is a deliberate and effective security control that prevents direct reconnaissance of the backend stack.

EVIDENCE

[Nmap scan report for www.news24.com \(104.17.251.6\)](#) Service: Cloudflare http proxy OS details: Not shown (hidden behind CDN)

BUSINESS IMPACT

- This is a POSITIVE security control
- Attackers cannot fingerprint the backend OS or software version
- Known CVEs cannot be directly targeted without origin IP knowledge

REMEDIATION

- ✓ Keep Cloudflare active as a protective reverse proxy layer
- ✓ Ensure origin IP is not exposed in DNS records, emails or error pages
- ✓ Rotate origin server IP if it has ever been publicly leaked

Risk Classification Summary

#	Finding	Risk	Likelihood	Impact
F1	Non-Standard Ports 8080/8443 Exposed	HIGH	Medium	High
F2	HTTP Port 80 Accepts Unencrypted Traffic	HIGH	Medium	High
F3	Outdated JS Library (insight.old.min.js)	MEDIUM	High	Medium
F4	Console Errors Publicly Visible (13 Issues)	MEDIUM	High	Medium
F5	First-Party Cookies Missing Secure Flag	MEDIUM	Medium	Medium
F6	Narrow Content-Security-Policy Scope	MEDIUM	Medium	Medium
F7	Deprecated Feature-Policy Header	LOW	Low	Low
F8	Cloudflare Rate Limiting Active	INFO	N/A	Positive
F9	Cloudflare Origin Server Masking	INFO	N/A	Positive

Recommendations

IMMEDIATE ACTIONS	LONG-TERM IMPROVEMENTS
✓ Close ports 8080 and 8443 via firewall if not required publicly ✓ Force HTTP to HTTPS redirect at Cloudflare level ✓ Enable HSTS with max-age of at least 1 year ✓ Remove or replace insight.old.min.js with current version ✓ Suppress JavaScript console output in production builds ✓ Set Secure and SameSite flags on all first-party cookies ✓ Expand Content-Security-Policy to cover script-src and img-src	✓ Conduct regular vulnerability assessments (quarterly minimum) ✓ Implement a WAF policy and security header review cycle ✓ Ensure Cloudflare origin IP is never exposed in DNS records ✓ Update Google Publisher Tag to remove deprecated API usage ✓ Implement JS dependency scanning in the CI/CD pipeline ✓ Adopt POPIA-compliant data handling for user cookie data ✓ Monitor for new CVEs affecting third-party scripts in use

Conclusion

Overall Risk Rating

MEDIUM

News24 demonstrates a strong security baseline, achieving an A grade on SecurityHeaders.com with HSTS, X-Frame-Options, X-Content-Type-Options, and Referrer-Policy all correctly configured. Cloudflare provides effective DDoS protection, rate limiting, and origin server masking — all confirmed as positive controls during this assessment.

However, two High-risk findings require prompt attention: the exposure of non-standard ports 8080 and 8443, and the acceptance of unencrypted HTTP traffic on port 80. An outdated JavaScript library (insight.old.min.js) actively throwing runtime errors, publicly visible console warnings, missing cookie Secure flags, and a narrow Content-Security-Policy represent medium-risk issues that should be addressed.

No critical vulnerabilities were identified. With targeted remediation of the findings above, News24's overall security posture would be rated LOW risk.